

XÂY DỰNG HỆ THỐNG MẠNG CÔNG TY ABC

BẢNG DANH SÁCH THÀNH VIÊN THỰC HIỆN ĐỀ TÀI

STT	Họ Và Tên	Phần thực hiện	Đánh giá
1	Nguyễn Anh Hoàng	Demo lab + làm word	100%
2	Lê Quang Long	Viết nội dung bài	100%

MỤC LỤC

Danh mục viết tắt	1
Chương 1. Bối cảnh và Cơ sở lý thuyết	2
1. Bối cảnh	2
1.2. Mạng được sử dụng trong bài	2
1.3. Cơ sở lý thuyết	3
1.3.1 Phần mềm ảo hóa (VMWare, VirtualBox,..)	3
1.3.2 Open VPN	3
1.3.3. AD DC (Active Directory, Domain Controller)	3
1.3.4. File Sever	3
1.3.5. FireWall	4
1.3.6. Web Server	4
1.3.7. Group Policy	4
1.3.8. BitLocker	4
Chương 2. Triển khai, giải pháp bảo mật	5
2.1 Triển khai môi trường	5
2.2. Giải pháp cho FireWall và VPN	5
2.3: Giải pháp AD DC (Active Directory, Domain Controller)	9
2.3.1. Giải pháp File Server	9
2.3.2. giải pháp Policy	11
2.2.3. Quản lý control panel	13
2.3.4 giải pháp BitLocker	14
2.4 giải pháp web server	16
2.5. Sơ đồ mạng của công ty	20
Chương 3. Kết luận, hạn chế và hướng phát triển	21
3.1. kết luận	21
3.2. Hạn chế	21
3.3. Hướng phát triển	22
TÀI LIỆU THAM KHẢO	23

MỤC LỤC HÌNH ẢNH

Hình 2.1: OpenVPN đã được setup.....	5
Hình 2.2: các máy bắt hợp pháp đang tấn công Brute Force	6
Hình 2.3: Nhật ký hệ thống (log) trên pfSense ghi nhận sshguard giám sát tấn công và các sự kiện đăng nhập	7
Hình 2.4: Cấu hình mạng giúp client có thể ping vào server	7
Hình 2.5: Kết quả ipconfig trên máy client (A.HN) cho thấy địa chỉ IP nội bộ 172.16.200.20 và IP được cấp qua đường hầm OpenVPN 10.8.0.2.....	8
Hình 2.6. Hình địa chỉ Domain Controller.....	9
Hình 2.7: Phân quyền NTFS cho các tài khoản (A.HCM, B.HCM, C.HCM, B.HN....) trên thư mục chia sẻ File Server	11
Hình 2.8: Cấu hình Password Policy và Account Lockout Policy qua Group Policy Management Editor	12
Hình 2.9: Chính sách GPO vô hiệu hóa Control Panel và Windows Settings	13
Hình 2.10: Thông báo từ chối truy cập hiển thị cho người dùng khi cố mở Control Panel	14
Hình 2.11: Trạng thái mã hóa BitLocker trên ổ đĩa hệ thống.....	15
Hình 2.12: Giao diện Web Server khi truy cập bằng địa chỉ IP/tên miền nội bộ	16
Hình 2.13: Tạo và cài đặt chứng chỉ số (Certificate) cho Web Server	17
Hình 2.14. Ràng buộc (binding) chứng chỉ SSL với cổng HTTPS (443) trên Web Server	18
Hình 2.15. Kết quả truy cập Web Server qua HTTPS sau khi cấu hình chứng chỉ thành công	19
Hình 2.16: Sơ đồ tổng thể hệ thống mạng của công ty (External Zone, DMZ Zone, Internal Zone)	20

Danh mục viết tắt

Viết tắt	Tên đầy đủ
BSD	Berkeley Software Distribution
VPN	Virtual Private Network
SSL/TLS	Secure Sockets Layer/ Transport Layer Security
DMZ	Demilitarized Zone
CPU	Central Processing Unit
RAM	Random Access Memory
AD DC	Active Directory/Domain Controller
IP	Internet Protocol
HTML	HyperText Markup Language
CSS	Cascading Style Sheets
PHP	Hypertext Preprocessor
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
GPO	Group Policy
TPM	Trusted Platform Module
NAT	Network Address Translation
WAN	Wide Area Network
NTFS	New Technology File System
MFA	Multi-Factor Authentication

Chương 1. Bối cảnh và Cơ sở lý thuyết

1. Bối cảnh

Công ty ABC là doanh nghiệp có quy mô hoạt động trải rộng trên ba miền của cả nước, với trụ sở chính đặt tại Quận 1, Thành phố Hồ Chí Minh và ba đơn vị trực thuộc gồm văn phòng đại diện khu vực phía Bắc tại quận Hoàn Kiếm, Hà Nội; văn phòng đại diện khu vực miền Trung tại thành phố Quy Nhơn, tỉnh Bình Định; và một nhà máy sản xuất đặt tại tỉnh Tiền Giang. Tổng số nhân sự toàn công ty vào khoảng 190 người, được phân bổ theo tỷ lệ 80 người tại trụ sở chính, 50 người tại Hà Nội, 30 người tại Quy Nhơn và 30 người tại nhà máy Tiền Giang.

Đặc điểm phân tán về địa lý này đặt ra hai bài toán song song cho bộ phận CNTT: thứ nhất là phải bảo đảm các chi nhánh có thể trao đổi dữ liệu, truy cập tài nguyên dùng chung (thư mục, ứng dụng nội bộ, cơ sở dữ liệu) với độ trễ chấp nhận được và không gián đoạn hoạt động kinh doanh; thứ hai là phải kiểm soát được rủi ro an toàn thông tin phát sinh từ việc mở rộng bề mặt tấn công ra nhiều điểm kết nối, nhiều loại thiết bị và nhiều nhóm người dùng có trình độ nhận thức bảo mật khác nhau.

1.2. Mạng được sử dụng trong bài

Network	Dải địa chỉ / Vai trò	Mô tả chức năng
1. Bridged Adapter	Theo mạng vật lý/ISP	Kết nối trực tiếp ra Internet hoặc mạng WAN của nhà cung cấp dịch vụ, đóng vai trò công biên (perimeter) của hệ thống ảo hóa/hạ tầng.
2. External Zone	172.16.10.0/24	Dành cho những máy kiểm thử như kali linux ...
3. DMZ Zone	172.16.100.0/24	Vùng phi quân sự hóa (Demilitarized Zone), cách ly Web Server và các dịch vụ công khai khác khỏi mạng nội bộ, hạn chế thiệt hại nếu bị tấn công.
4. Internal Zone	172.16.200.0/24	Vùng mạng nội bộ chứa Domain Controller, File Server và máy trạm người dùng — vùng có yêu cầu bảo mật cao nhất, không cho phép truy cập trực tiếp từ Internet.

1.3. Cơ sở lý thuyết

1.3.1 Phần mềm ảo hóa (VMWare, VirtualBox,...)

Phần mềm ảo hóa là công nghệ cho phép một máy tính vật lý (Host) tạo và vận hành nhiều máy tính ảo (Virtual Machine - VM) trên cùng một phần cứng. Mỗi máy ảo hoạt động như một máy tính độc lập, có hệ điều hành, CPU, RAM, ổ cứng, card mạng và các tài nguyên riêng được cấp phát từ máy chủ vật lý.

Công nghệ ảo hóa giúp nhiều hệ điều hành như Windows, Linux hoặc Windows Server có thể chạy đồng thời trên cùng một máy tính mà không ảnh hưởng lẫn nhau. Nhờ đó, người dùng có thể thử nghiệm, phát triển phần mềm, xây dựng hệ thống mạng, mô phỏng môi trường máy chủ và kiểm thử các cấu hình một cách an toàn, tiết kiệm chi phí và dễ dàng quản lý.

1.3.2 Open VPN

OpenVPN là giải pháp mạng riêng ảo (Virtual Private Network - VPN) mã nguồn mở được sử dụng rộng rãi để thiết lập kết nối an toàn giữa người dùng và mạng nội bộ thông qua Internet. OpenVPN sử dụng các giao thức SSL/TLS cùng các thuật toán mã hóa mạnh để bảo vệ tính bảo mật, toàn vẹn và xác thực dữ liệu trong quá trình truyền tải.

OpenVPN hoạt động bằng cách tạo một đường hầm mã hóa (Encrypted Tunnel) giữa thiết bị người dùng (Client) và máy chủ VPN (Domain Controller). Mọi dữ liệu truyền qua đường hầm này đều được mã hóa, giúp ngăn chặn việc nghe lén, đánh cắp thông tin hoặc giả mạo dữ liệu khi truyền trên mạng công cộng. Nhờ đó, người dùng có thể truy cập từ xa vào tài nguyên của mạng nội bộ một cách an toàn như đang làm việc trực tiếp trong mạng doanh nghiệp.

1.3.3. AD DC (Active Directory, Domain Controller)

Active Directory (AD) là dịch vụ thư mục của Microsoft được tích hợp trên Windows Server, dùng để quản lý tập trung người dùng, máy tính, nhóm và các tài nguyên trong mạng. AD cho phép quản trị viên tạo tài khoản, phân quyền truy cập, áp dụng các chính sách bảo mật (Group Policy) và quản lý toàn bộ hệ thống từ một vị trí duy nhất, giúp tăng tính bảo mật và hiệu quả quản trị.

Domain Controller (DC) là máy chủ cài đặt dịch vụ Active Directory Domain Services (AD DS), có nhiệm vụ lưu trữ cơ sở dữ liệu Active Directory và thực hiện xác thực (Authentication) cũng như phân quyền (Authorization) cho người dùng và thiết bị trong miền (Domain). Ngoài ra, DC còn quản lý tài khoản, thực thi Group Policy, đồng bộ dữ liệu giữa các Domain Controller và đảm bảo người dùng chỉ được truy cập vào những tài nguyên mà họ được cấp quyền.

1.3.4. File Sever

File Server là máy chủ dùng để lưu trữ, quản lý và chia sẻ các tệp tin (tài liệu, hình ảnh, video, cơ sở dữ liệu,...) cho các máy tính khác trong mạng. File Server giúp tập trung dữ liệu tại một nơi, thay vì lưu trữ phân tán trên từng máy người dùng, từ đó giúp việc quản lý và truy cập dữ liệu trở nên thuận tiện hơn. Ngoài chức năng lưu trữ, File Server còn cho phép phân quyền truy cập cho từng người dùng hoặc nhóm người dùng (chỉ đọc, đọc/ghi, toàn quyền), đảm bảo an

toàn dữ liệu. Đồng thời, máy chủ hỗ trợ sao lưu (backup), khôi phục dữ liệu khi cần và giúp nhiều người dùng có thể truy cập, chia sẻ tệp tin một cách nhanh chóng và hiệu quả trong cùng hệ thống mạng.

1.3.5. FireWall

Firewall là hệ thống bảo mật mạng (phần cứng hoặc phần mềm) có chức năng giám sát, lọc và kiểm soát lưu lượng dữ liệu ra vào mạng dựa trên các quy tắc bảo mật được cấu hình trước. Firewall giúp ngăn chặn các truy cập trái phép, mã độc và các cuộc tấn công từ bên ngoài, đồng thời chỉ cho phép những kết nối hợp lệ được truy cập vào hệ thống. Ngoài ra, Firewall còn có khả năng kiểm soát lưu lượng theo địa chỉ IP, cổng (Port), giao thức hoặc ứng dụng, giúp bảo vệ mạng nội bộ, đảm bảo an toàn dữ liệu và nâng cao mức độ bảo mật cho toàn bộ hệ thống.

1.3.6. Web Server

Web Server là máy chủ dùng để lưu trữ và cung cấp nội dung của các trang web như tệp HTML, CSS, JavaScript, PHP, hình ảnh và các tài nguyên khác. Web Server tiếp nhận các yêu cầu từ trình duyệt của người dùng thông qua giao thức HTTP hoặc HTTPS, sau đó xử lý và gửi lại nội dung trang web tương ứng. Ngoài việc cung cấp nội dung web, Web Server còn hỗ trợ quản lý nhiều website, xử lý các yêu cầu truy cập đồng thời và kết hợp với các cơ chế bảo mật như HTTPS (SSL/TLS) để đảm bảo việc truyền tải dữ liệu an toàn giữa máy chủ và người dùng.

1.3.7. Group Policy

Group Policy (GPO) là tính năng của Active Directory cho phép quản trị viên cấu hình và quản lý tập trung các thiết lập đối với người dùng và máy tính trong miền (Domain). GPO giúp tự động áp dụng các chính sách bảo mật, cấu hình hệ thống, cài đặt phần mềm và quyền truy cập mà không cần thiết lập thủ công trên từng máy tính, từ đó đảm bảo tính nhất quán và tăng cường bảo mật cho toàn hệ thống. Ví dụ, quản trị viên có thể quy định mật khẩu phải có tối thiểu 8 ký tự, bao gồm chữ hoa, chữ thường, số và ký tự đặc biệt; yêu cầu người dùng thay đổi mật khẩu sau mỗi 30 ngày, ghi nhớ 10 mật khẩu gần nhất để tránh sử dụng lại mật khẩu cũ, hoặc vô hiệu hóa các tính năng như USB, Control Panel và Command Prompt đối với một số nhóm người dùng nhất định.

1.3.8. BitLocker

BitLocker là tính năng mã hóa toàn bộ ổ đĩa (Full Disk Encryption) được tích hợp trên các phiên bản Windows Pro, Enterprise và Education. BitLocker sử dụng các thuật toán mã hóa mạnh để bảo vệ dữ liệu trên ổ đĩa khỏi các truy cập trái phép, ngay cả khi thiết bị bị mất, bị đánh cắp hoặc ổ cứng bị tháo lắp sang máy tính khác. BitLocker có thể hoạt động kết hợp với Trusted Platform Module (TPM) để lưu trữ khóa mã hóa một cách an toàn hoặc sử dụng mật khẩu, USB khởi động và Recovery Key để xác thực khi cần. Nhờ đó, dữ liệu chỉ có thể được truy cập bởi người dùng được cấp quyền, góp phần bảo vệ thông tin quan trọng và nâng cao an toàn cho hệ thống.

Chương 2. Triển khai, giải pháp bảo mật

2.1 Triển khai môi trường

Hệ điều hành	Cấu hình	NetWork sử dụng	Vai trò
BSD (NetGate)	memory(RAM): 1024MB CPU: 1 Disk Size: 16GB	Bridged Adapter DMZ Zone Internal Zone	FireWall
Windows Server 2022	memory(RAM): 2048MB CPU: 2 Disk Size: 80GB	Internal Zone	DC1 (Domain Controller, File Server)
Windows Server 2022	memory(RAM): 2048MB CPU: 2 Disk Size: 50GB	DMZ Zone	DC2 (Web Sever)
Windows 10	memory(RAM): 2048MB CPU: 2 Disk Size: 60GB	Internal Zone	Client (Các máy user)

2.2. Giải pháp cho FireWall và VPN

Floating

WAN

LAN

OPT1

OPT2

OpenVPN

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/1 KiB	*	RFC 1918 networks	*	*	*	*	*		Block private networks	
☒	0/0 B	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	
☐	0/0 B	IPv4 TCP	*	*	172.16.100.10	443 (HTTPS)	*	none		NAT NAT HTTPS to DMZ Web Server	
☐	0/0 B	IPv4 UDP	*	*	WAN address	1194 (OpenVPN)	*	none		OpenVPN Lab_VPN_Server wizard	

Hình 2.1: OpenVPN đã được setup

Mô hình mạng đang áp dụng một kiến trúc phòng thủ theo chiều sâu (Defense-in-Depth) chặt chẽ và tuân thủ nguyên tắc đặc quyền tối thiểu (Least Privilege). Ở lớp ranh giới ngoài cùng, giao diện WAN được thiết lập các quy tắc kiểm soát truy cập nghiêm ngặt nhằm chặn đứng mọi nguồn địa chỉ IP nội bộ (RFC 1918) khi các nhân viên vào sử dụng thì sẽ được cấp các IP trong vùng 10.8.0.0/24 hoàn toàn không nằm chung địa chỉ IP với Web Server hay Domain Controller hoặc không hợp lệ (Bogon) xâm nhập từ Internet, giúp chống lại kỹ thuật tấn công giả mạo địa chỉ (IP Spoofing).

Normal View Dynamic View Summary View						
Last 308 Firewall Log Entries. (Maximum 500)						
Action	Time	Interface	Rule	Source	Destination	Protocol
✗	Jul 21 14:09:15	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:15	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:15	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	block bogon IPv4 networks from WAN (11001)	i 0.0.0.0:68	i 255.255.255.255:67	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN block 192.168/16 (12004)	i 192.168.1.4:137	i 192.168.1.255:137	UDP
✗	Jul 21 14:09:16	WAN	Block private networks from WAN	i 192.168.1.4:137	i 192.168.1.255:137	UDP

Hình 2.2: các máy bất hợp pháp đang tấn công Brute Force

Hiệu quả của lớp bảo vệ (Defense-in-Depth) này được minh chứng rõ nét qua nhật ký tường lửa như trên hình 2.2, khi hệ thống liên tục nhận diện và chủ động đánh rớt (Block) các gói tin UDP bất hợp pháp mang địa chỉ nguồn nội bộ (ví dụ: 192.168.1.4 hay 0.0.0.0) đang cố gắng rà quét vào mạng.

Last 36 General Log Entries. (Maximum 500)			
Time	Process	PID	Message
Jul 21 20:59:59	sshguard	16952	Now monitoring attacks.
Jul 21 14:00:53	sshguard	16952	Exiting on signal.
Jul 21 14:00:53	sshguard	30061	Now monitoring attacks.
Jul 21 14:01:01	login	92768	login on ttyv0 as root
Jul 21 14:19:05	php-fpm	424	/index.php: Successful login for user 'admin' from: 172.16.200.10 (Local Database)
Jul 21 14:26:41	login	37906	login on ttyv0 as root
Jul 21 14:42:17	php-fpm	424	/index.php: Successful login for user 'admin' from: 172.16.200.10 (Local Database)
Jul 21 14:58:53	login	60441	login on ttyv0 as root
Jul 21 23:13:56	sshguard	16068	Now monitoring attacks.
Jul 21 23:17:02	sshguard	16068	Exiting on signal.
Jul 21 23:17:05	sshguard	92390	Now monitoring attacks.
Jul 21 23:17:26	login	51339	login on ttyv0 as root
Jul 21 16:27:25	php-fpm	435	/index.php: Successful login for user 'admin' from: 172.16.200.10 (Local Database)
Jul 22 00:05:51	sshguard	15227	Now monitoring attacks.
Jul 21 17:06:42	sshguard	15227	Exiting on signal.

Hình 2.3: Nhật ký hệ thống (log) trên pfSense ghi nhận sshguard giám sát tấn công và các sự kiện đăng nhập

Sau khi cấu hình các chính sách trên Firewall, hệ thống sử dụng chức năng System Log của pfSense để giám sát và ghi nhận toàn bộ các sự kiện phát sinh trong quá trình hoạt động. Nhật ký lưu lại thông tin về thời gian, dịch vụ đang hoạt động, các phiên đăng nhập và các cảnh báo bảo mật, giúp quản trị viên theo dõi tình trạng của hệ thống theo thời gian thực.

Bên cạnh đó, dịch vụ sshguard được tích hợp trên pfSense có nhiệm vụ giám sát các kết nối từ xa và phát hiện các hành vi đăng nhập bất thường hoặc có dấu hiệu tấn công. Việc kết hợp giữa Firewall và hệ thống ghi nhật ký giúp quản trị viên dễ dàng kiểm tra, phát hiện các sự cố, đồng thời đánh giá hiệu quả của các chính sách bảo mật và kết nối VPN đã triển khai. Điều này góp phần nâng cao khả năng giám sát, tăng cường tính an toàn và đảm bảo hệ thống mạng luôn hoạt động ổn định.

Port Forward 1:1 Outbound NPT										
Rules										
☐	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
☐	☒ WAN	TCP	*	*	WAN address	443 (HTTPS)	172.16.100.10	443 (HTTPS)	NAT HTTPS to DMZ Web Server	  

 Add
 Add
 Delete
 Toggle
 Save
 Separator

Hình 2.4: Cấu hình mạng giúp client có thể ping vào server

Đồng thời, hệ thống thu hẹp tối đa bề mặt tấn công (attack surface) bằng cách chỉ cho phép đúng hai luồng giao tiếp thiết yếu đi qua WAN: luồng dữ liệu quản trị từ xa an toàn qua đường hầm mã hóa OpenVPN (UDP 1194) và luồng truy cập dịch vụ Web (TCP 443). Thay vì định tuyến trực tiếp, luồng web này bị ép buộc đi qua cơ chế biên dịch địa chỉ mạng NAT Port Forwarding (Hình 2.2)

Các cấu hình Firewall và VPN nêu trên có vai trò kiểm soát và lọc toàn bộ lưu lượng ra/vào giữa mạng nội bộ, vùng DMZ và Internet, đồng thời cung cấp kênh truy cập từ xa được mã hóa cho quản trị viên và nhân viên làm việc ngoài văn phòng. Hạn chế tác nhân tấn công từ bên ngoài Internet (hacker, bot quét mạng tự động), tấn công giả mạo địa chỉ nguồn (IP Spoofing), truy cập trái phép khi dữ liệu truyền qua mạng công cộng, cũng như thu hẹp bề mặt tấn công do hạn chế tối đa số lượng dịch vụ/cổng bị lộ ra ngoài.

```
C:\Users\A.HN>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::e819:50eb:1d3a:3667%4
    IPv4 Address. . . . . : 172.16.200.20
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 172.16.200.1

Unknown adapter OpenVPN TAP-Windows6:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::113:d5d3:ff6:207f%24
    IPv4 Address. . . . . : 10.8.0.2
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

Unknown adapter OpenVPN Data Channel Offload:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

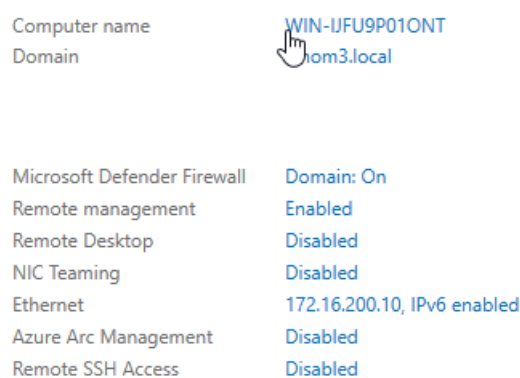
C:\Users\A.HN>_
```

Hình 2.5: Kết quả ipconfig trên máy client (A.HN) cho thấy địa chỉ IP nội bộ 172.16.200.20 và IP được cấp qua đường hầm OpenVPN 10.8.0.2

Sau khi kết nối OpenVPN, máy khách vẫn giữ địa chỉ IP nội bộ 172.16.200.20 và đồng thời được cấp thêm địa chỉ IP 10.8.0.2 thuộc dải mạng 10.8.0.0/24. Địa chỉ IP này được sử dụng để định danh thiết bị trên đường hầm VPN, giúp các kết nối từ xa được định tuyến an toàn và tách biệt với mạng nội bộ. Việc sử dụng dải địa chỉ riêng cho VPN giúp quản trị viên dễ dàng quản lý, giám sát và áp dụng các chính sách Firewall phù hợp, góp phần nâng cao tính bảo mật của hệ thống mạng.

Giải pháp này không chỉ bảo vệ dữ liệu trong quá trình truyền tải mà còn hỗ trợ quản lý, kiểm soát các kết nối từ xa một cách hiệu quả. Bên cạnh đó, việc sử dụng dải địa chỉ IP riêng cho VPN giúp quản trị viên dễ dàng nhận diện, giám sát và áp dụng các chính sách Firewall phù hợp đối với các phiên kết nối, góp phần nâng cao tính bảo mật và ổn định của hệ thống mạng.

2.3: Giải pháp AD DC (Active Directory, Domain Controller)



Computer name	WIN-IJFU9P01ONT
Domain	hom3.local
Microsoft Defender Firewall	Domain: On
Remote management	Enabled
Remote Desktop	Disabled
NIC Teaming	Disabled
Ethernet	172.16.200.10, IPv6 enabled
Azure Arc Management	Disabled
Remote SSH Access	Disabled

Hình 2.6. Hình địa chỉ Domain Controller

Trọng tâm của kiến trúc này là sự tích hợp giữa AD DC và máy chủ chia sẻ tài nguyên (File Server). Thông qua cơ chế Phân quyền và Giới hạn quyền quản trị, hệ thống áp dụng triệt để nguyên tắc đặc quyền tối thiểu (Least Privilege). Việc cấp phát quyền truy cập được thiết kế tinh gọn theo từng vai trò của người dùng và phòng ban, đảm bảo dữ liệu trên File Server được cô lập an toàn và ngăn chặn tối đa rủi ro lạm quyền hoặc di chuyển ngang (Lateral Movement) trong mạng nội bộ.

Nhằm bảo vệ hệ thống trước các kỹ thuật tấn công phổ biến như dò đoán mật khẩu (Brute-force/Dictionary Attacks), Chính sách Mật khẩu và Khóa tài khoản (Password & Account Lockout Policies) đã được cấu hình và ép buộc đồng bộ qua Group Policy (GPO). Các chính sách này thiết lập rào cản vững chắc cho quá trình xác thực, yêu cầu tính phức tạp của thông tin đăng nhập và tự động vô hiệu hóa các tài khoản có dấu hiệu bị rà quét.

Cuối cùng, để hoàn thiện bức tranh bảo mật từ mức logic đến mức vật lý, công nghệ mã hóa BitLocker được triển khai nhằm bảo vệ dữ liệu ở trạng thái nghỉ (Data at Rest). Giải pháp này đảm bảo rằng ngay cả trong kịch bản máy chủ bị xâm nhập vật lý hoặc các thiết bị lưu trữ bị đánh cắp, toàn bộ cấu trúc cơ sở dữ liệu của AD DC và tài nguyên trên File Server vẫn được mã hóa an toàn, không thể bị truy xuất trái phép. Sự kết hợp đồng bộ giữa kiểm soát định danh, phân quyền tài nguyên và mã hóa ổ đĩa tạo nên một hạ tầng hạ tầng mạng đáng tin cậy và linh hoạt.

2.3.1. Giải pháp File Server

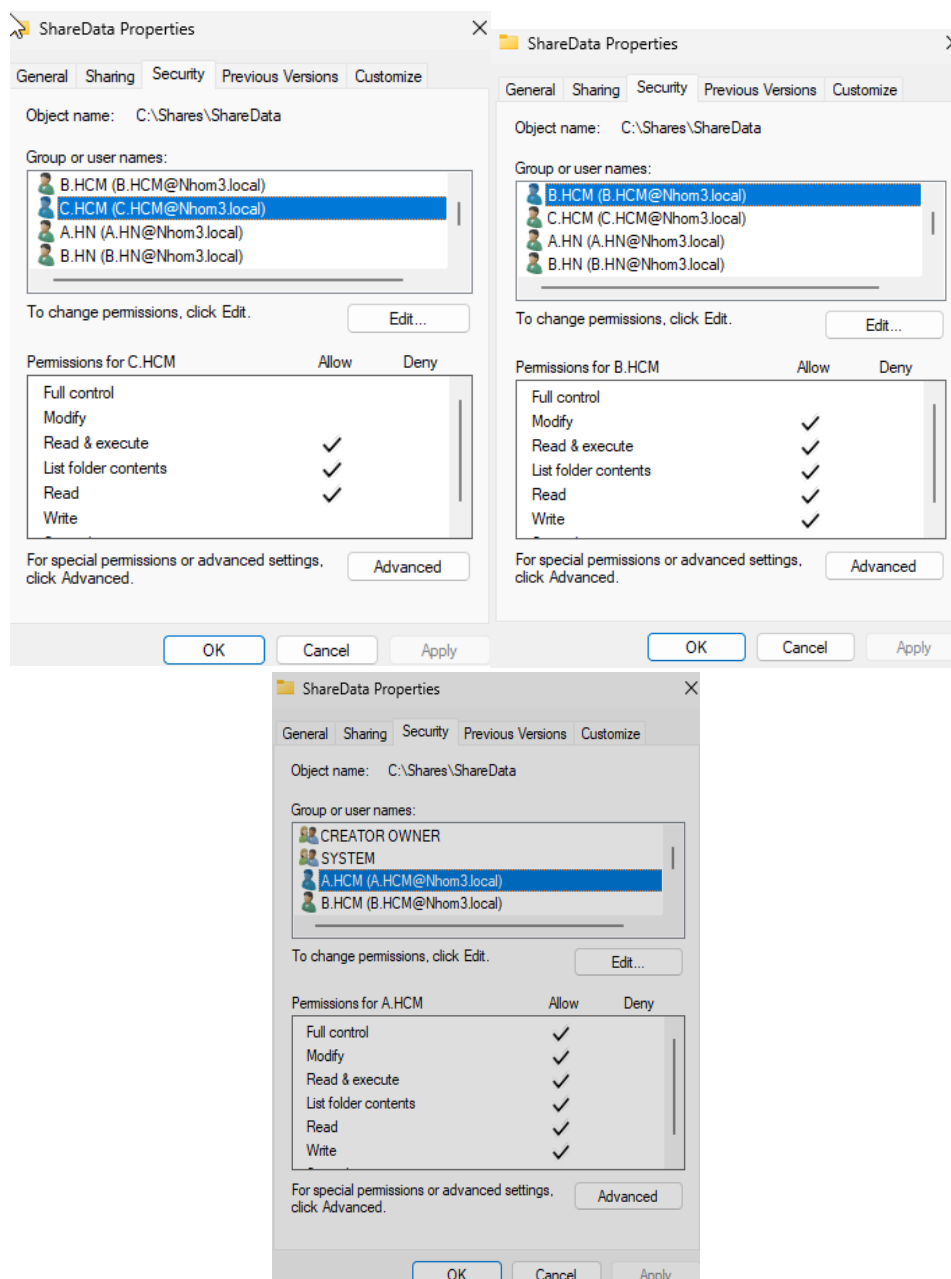
Giải pháp File Server được triển khai nhằm xây dựng hệ thống lưu trữ dữ liệu tập trung, cho phép người dùng trong môi trường Domain truy cập và chia sẻ tài nguyên một cách thuận tiện. Việc lưu trữ tập trung giúp dữ liệu được quản lý thống nhất, giảm tình trạng phân tán dữ liệu

trên nhiều máy tính, đồng thời tạo điều kiện thuận lợi cho công tác quản lý, sao lưu và khôi phục khi xảy ra sự cố.

Để đảm bảo an toàn dữ liệu, hệ thống áp dụng cơ chế phân quyền truy cập thông qua Active Directory kết hợp với NTFS Permissions. Mỗi người dùng được cấp quyền phù hợp với vai trò và phạm vi công việc, từ đó kiểm soát chặt chẽ việc truy cập, chỉnh sửa hoặc quản lý dữ liệu trên máy chủ.

Tài khoản các quản lý các chi nhánh như (A.HCM, A.HN..) được cấp quyền Full Control, cho phép thực hiện toàn bộ các thao tác như đọc, ghi, chỉnh sửa, xóa và thay đổi quyền truy cập đối với thư mục chia sẻ. Trong khi đó, các tài khoản (B.HCM, C.HCM và B.HN...) chỉ được cấp các quyền Modify, Read & Execute, List Folder Contents, Read và Write, đáp ứng nhu cầu sử dụng dữ liệu hằng ngày nhưng không được phép thay đổi quyền hoặc cấu hình bảo mật của thư mục.

Việc phân quyền theo từng tài khoản giúp đảm bảo nguyên tắc Least Privilege (Đặc quyền tối thiểu), nghĩa là mỗi người dùng chỉ được cấp đúng những quyền cần thiết để thực hiện công việc. Giải pháp này góp phần hạn chế truy cập trái phép, giảm nguy cơ thay đổi hoặc xóa dữ liệu ngoài ý muốn, đồng thời nâng cao tính bảo mật và khả năng quản lý dữ liệu trong hệ thống.



Hình 2.7: Phân quyền NTFS cho các tài khoản (A.HCM, B.HCM, C.HCM, B.HN....) trên thư mục chia sẻ File Server

Cung cấp nơi lưu trữ dữ liệu tập trung, đồng thời phân quyền truy cập chi tiết theo từng tài khoản, phòng ban dựa trên nguyên tắc đặc quyền tối thiểu (Least Privilege). Hạn chế hành vi truy cập, sao chép hoặc chỉnh sửa dữ liệu ngoài phạm vi công việc; nguy cơ nội gián (insider threat) hoặc tài khoản bị chiếm quyền di chuyển ngang (Lateral Movement) sang các tài nguyên không được phép truy cập.

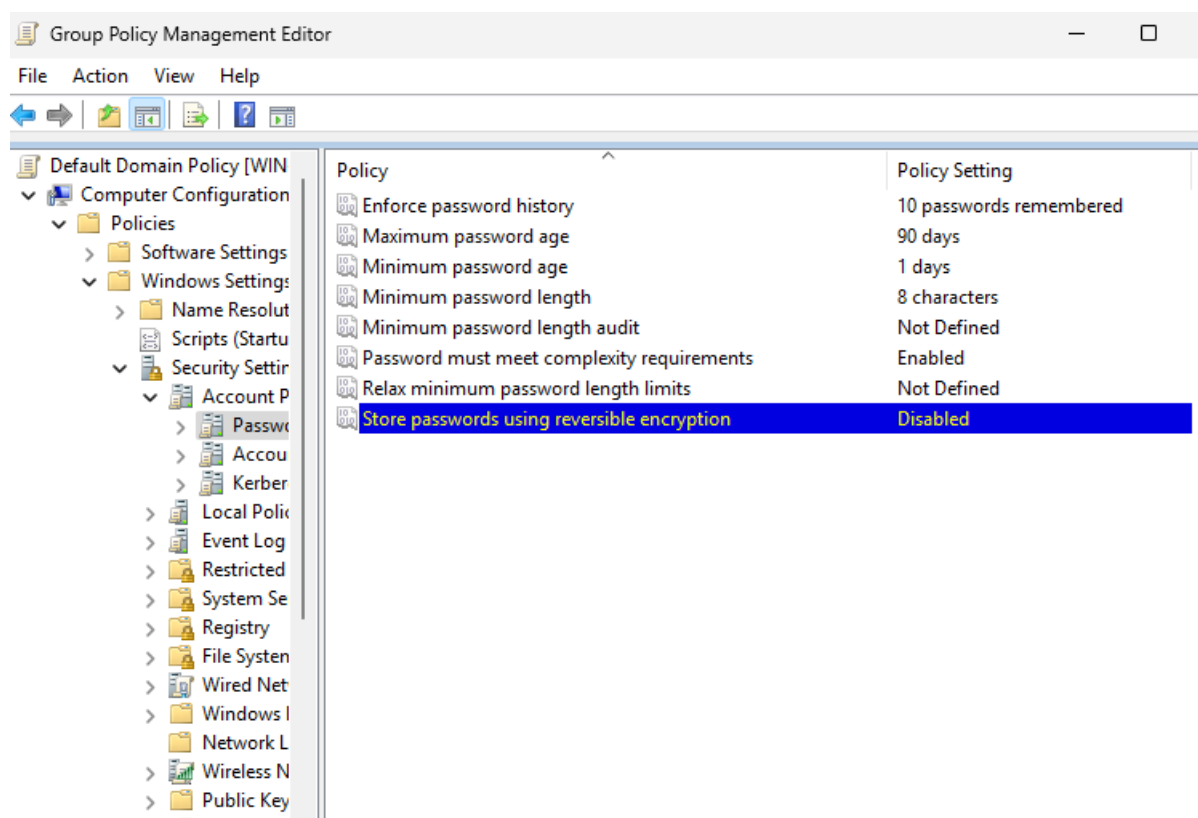
2.3.2. giải pháp Policy

Giải pháp Policy được triển khai thông qua Group Policy Objects (GPO) trong môi trường Active Directory nhằm quản lý tập trung các thiết lập bảo mật và cấu hình hệ thống đối với

người dùng và máy tính. Việc áp dụng Group Policy giúp các chính sách được triển khai đồng bộ trên toàn bộ Domain, giảm thiểu sai sót trong quá trình cấu hình thủ công và nâng cao hiệu quả quản trị hệ thống.

Các chính sách được cấu hình bao gồm Password Policy nhằm yêu cầu mật khẩu có độ phức tạp và thời gian sử dụng phù hợp, Account Lockout Policy để tự động khóa tài khoản khi đăng nhập sai nhiều lần, góp phần hạn chế các cuộc tấn công dò đoán mật khẩu. Bên cạnh đó, hệ thống cũng triển khai các chính sách quản lý người dùng như hạn chế truy cập Control Panel, Command Prompt, Registry Editor và một số thiết lập hệ thống nhằm ngăn chặn việc tự ý thay đổi cấu hình hoặc làm ảnh hưởng đến hoạt động của máy tính trong Domain.

Việc triển khai Group Policy giúp chuẩn hóa cấu hình bảo mật trên toàn hệ thống, tăng cường khả năng kiểm soát người dùng và thiết bị, đồng thời giảm thiểu các rủi ro phát sinh từ việc cấu hình không đồng nhất hoặc thay đổi trái phép.

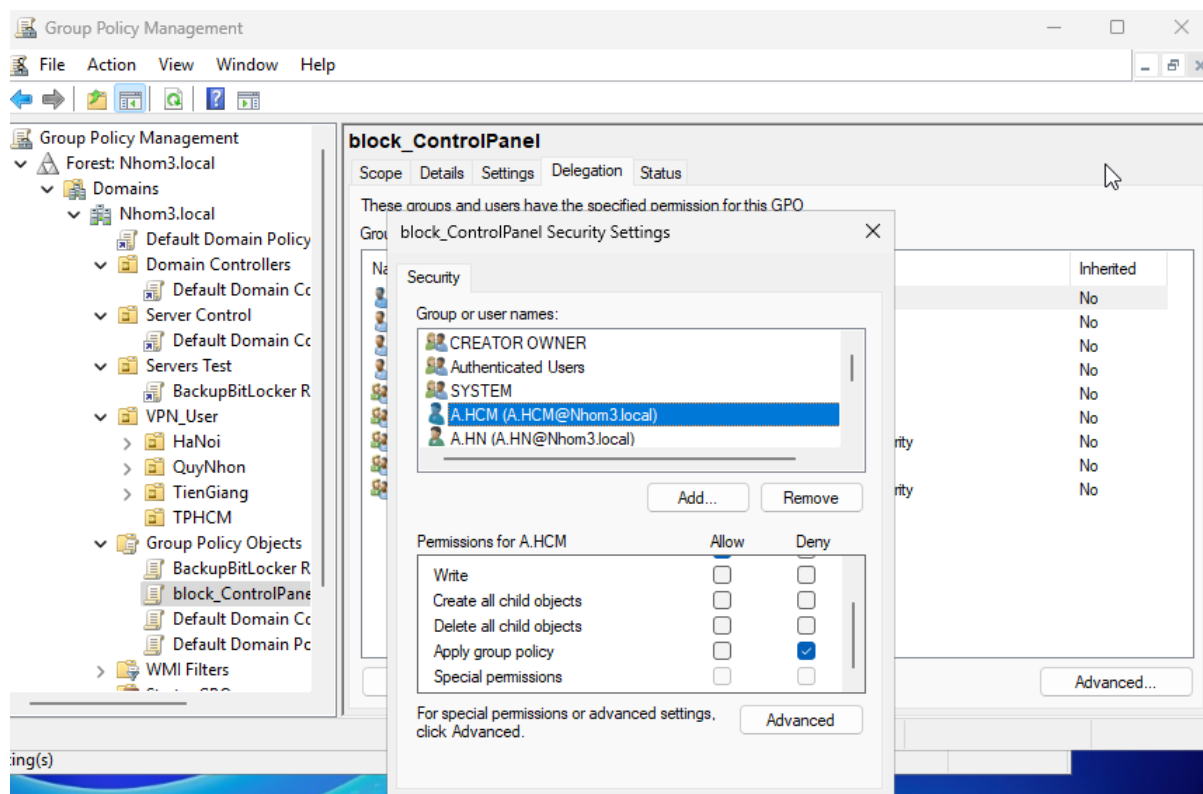


Hình 2.8: Cấu hình Password Policy và Account Lockout Policy qua Group Policy Management Editor

Áp đặt và đồng bộ các chính sách bảo mật, cấu hình hệ thống trên toàn bộ máy trạm và người dùng trong Domain mà không cần cấu hình thủ công từng máy. Hạn chế các sai sót do cấu hình thủ công không đồng nhất giữa các máy; hành vi người dùng tự ý thay đổi thiết lập hệ thống hoặc vô hiệu hóa các cơ chế bảo vệ đã thiết lập sẵn; đồng thời góp phần hạn chế các cuộc tấn công dò đoán mật khẩu nhờ Password và Account Lockout Policy.

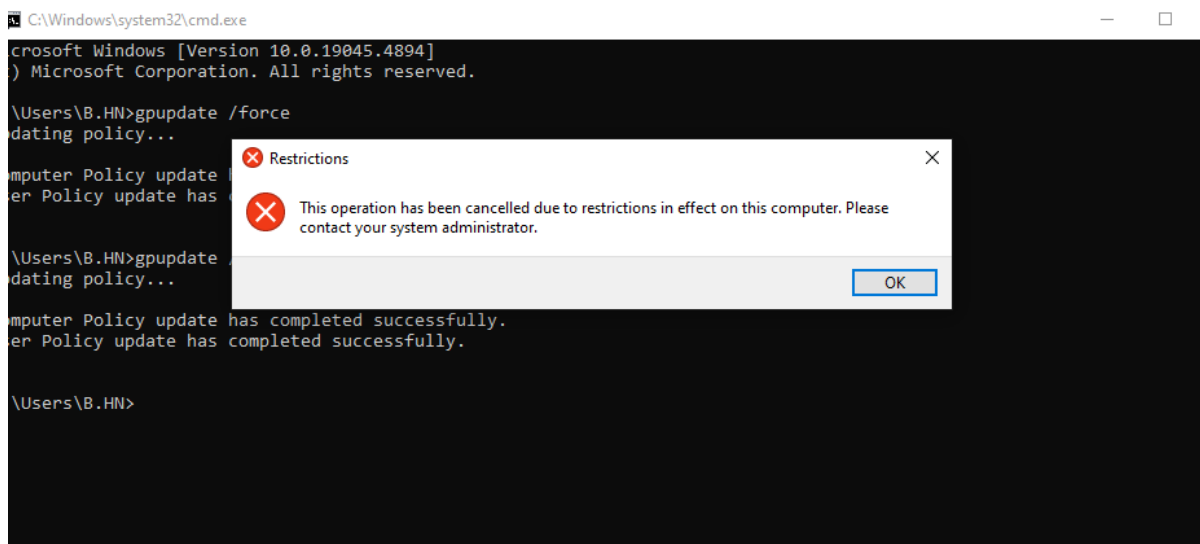
2.2.3. Quản lý control panel

Giải pháp Quản lý Control Panel được triển khai thông qua Group Policy (GPO) trong môi trường Active Directory nhằm kiểm soát quyền truy cập của người dùng đối với các thiết lập hệ thống. Chính sách này cho phép quản trị viên quản lý tập trung và áp dụng đồng bộ trên các máy tính thuộc Domain, đảm bảo người dùng chỉ được sử dụng các chức năng cần thiết trong quá trình làm việc.



Hình 2.9: Chính sách GPO vô hiệu hóa Control Panel và Windows Settings

Đối với người dùng thông thường, quyền truy cập vào Control Panel và Windows Settings được vô hiệu hóa nhằm ngăn chặn việc tự ý thay đổi các thiết lập như cấu hình mạng, tài khoản người dùng, chương trình cài đặt hoặc các thông số hệ thống khác. Khi người dùng cố gắng truy cập, hệ thống sẽ tự động từ chối và hiển thị thông báo cho biết thao tác đã bị chặn bởi chính sách do quản trị viên thiết lập.



Hình 2.10: Thông báo từ chối truy cập hiển thị cho người dùng khi cố mở Control Panel

Việc triển khai chính sách này giúp chuẩn hóa cấu hình trên toàn bộ hệ thống, hạn chế các thay đổi ngoài ý muốn, giảm nguy cơ mất ổn định của máy tính và tăng cường khả năng bảo vệ môi trường Domain trước các hành vi can thiệp trái phép từ phía người dùng.

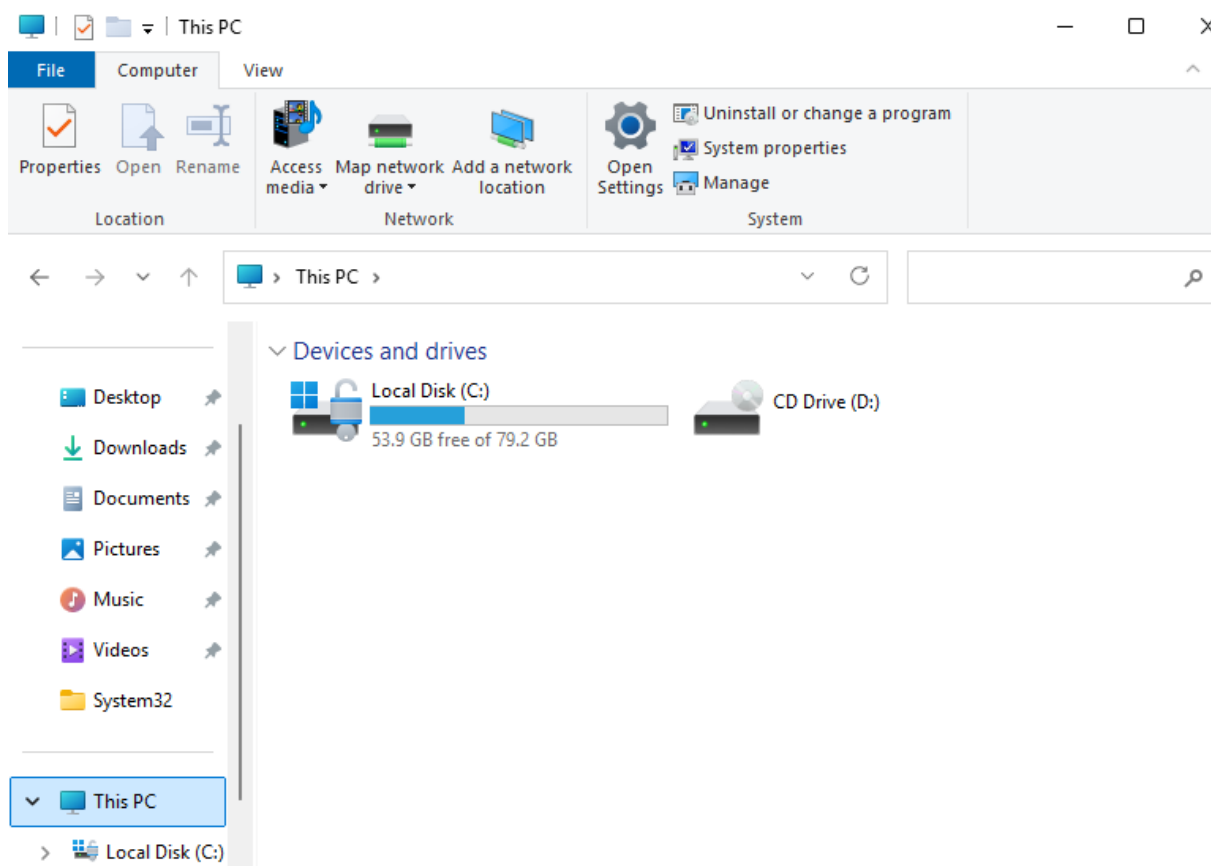
Giới hạn quyền truy cập của người dùng phổ thông vào các công cụ quản trị hệ thống như Control Panel, Command Prompt, Registry Editor. Hạn chế nguy cơ người dùng nội bộ (dù vô tình hay cố ý) làm thay đổi cấu hình mạng, gỡ bỏ phần mềm bảo vệ, hoặc tạo điều kiện cho mã độc thực thi thông qua các công cụ quản trị cấp cao.

2.3.4 giải pháp BitLocker

Giải pháp BitLocker được triển khai nhằm bảo vệ dữ liệu trên các thiết bị đầu cuối thông qua cơ chế mã hóa toàn bộ ổ đĩa. Khi được kích hoạt, dữ liệu lưu trữ trên ổ cứng sẽ được mã hóa, giúp ngăn chặn việc truy cập trái phép trong trường hợp thiết bị bị mất, bị đánh cắp hoặc ổ cứng bị tháo rời để truy xuất dữ liệu trên máy tính khác.

Việc quản lý BitLocker được thực hiện trên các máy tính thuộc môi trường Domain, giúp đảm bảo dữ liệu luôn được bảo vệ mà không làm ảnh hưởng đến quá trình sử dụng của người dùng. Chỉ những người dùng hoặc quản trị viên được cấp quyền mới có thể giải mã và truy cập vào dữ liệu trên ổ đĩa.

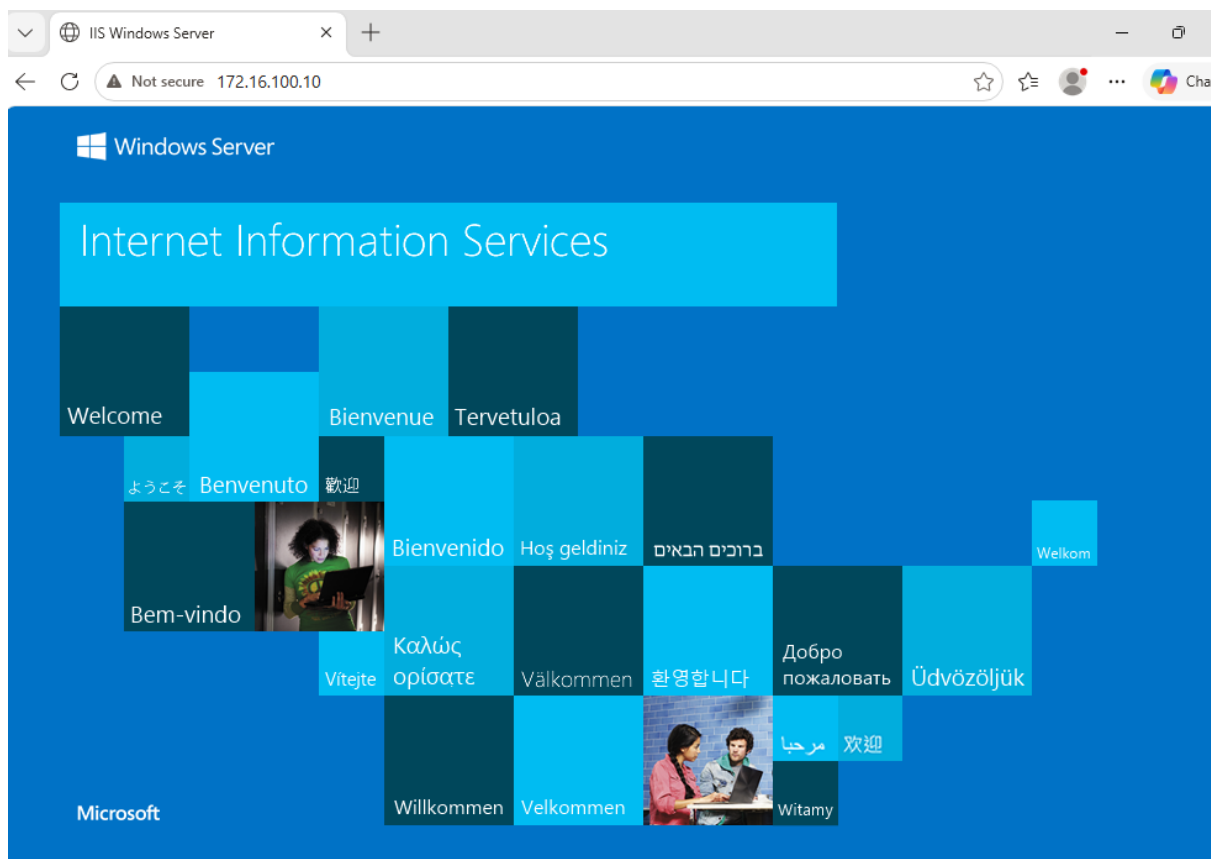
Giải pháp này góp phần tăng cường bảo mật cho dữ liệu ở trạng thái lưu trữ (Data at Rest), giảm thiểu nguy cơ rò rỉ thông tin và đáp ứng yêu cầu bảo vệ dữ liệu trên các thiết bị đầu cuối. Đồng thời, việc kết hợp BitLocker với các chính sách quản lý tập trung trong Active Directory giúp nâng cao hiệu quả quản trị và đảm bảo an toàn cho toàn bộ hệ thống.



Hình 2.11: Trạng thái mã hóa BitLocker trên ổ đĩa hệ thống

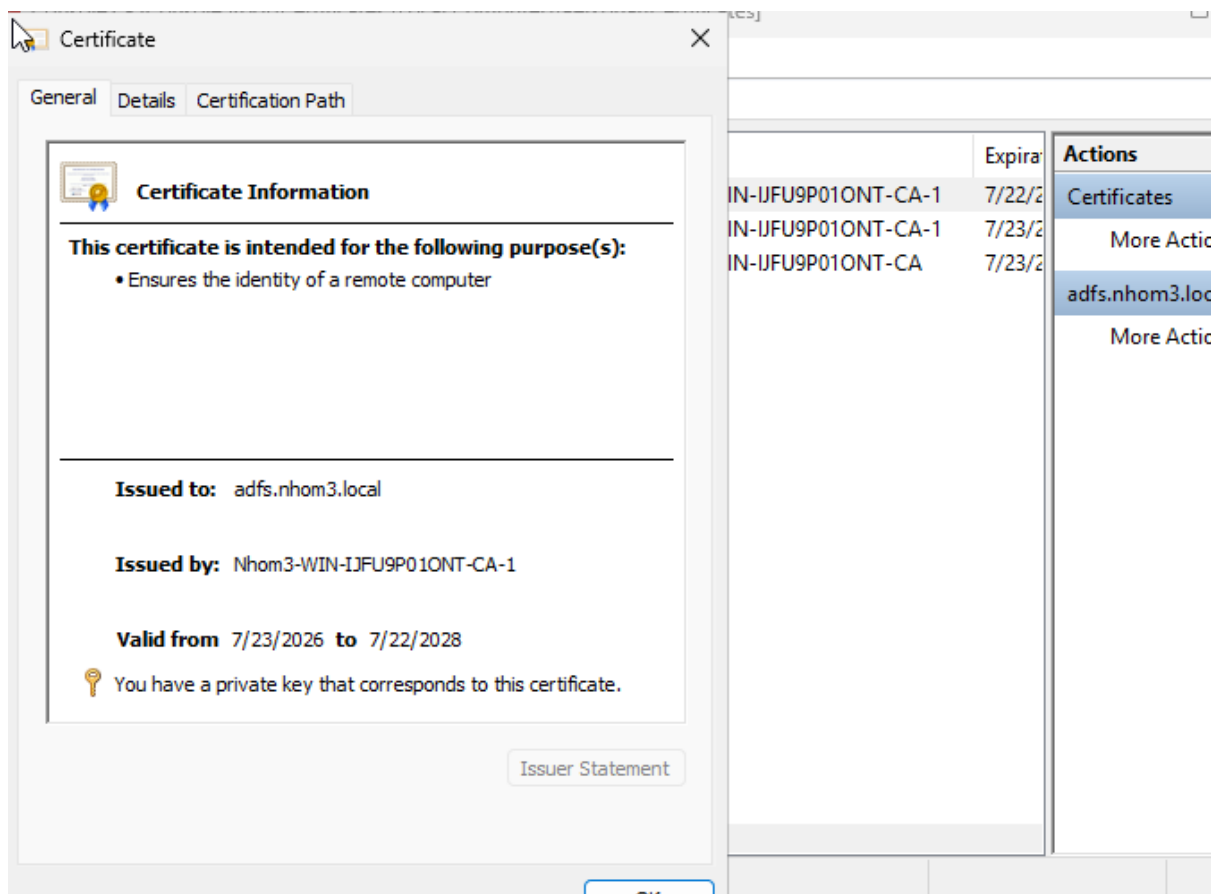
Mã hóa toàn bộ ổ đĩa trên các thiết bị đầu cuối và máy chủ, bảo vệ dữ liệu ở trạng thái lưu trữ (Data at Rest). Hạn chế được rủi ro rò rỉ dữ liệu khi thiết bị bị mất, bị đánh cắp hoặc ổ cứng bị tháo rời để trích xuất dữ liệu trên máy khác; đây là hàng rào bảo vệ cuối cùng khi các lớp bảo mật khác đã bị vượt qua.

2.4 giải pháp web server



Hình 2.12: Giao diện Web Server khi truy cập bằng địa chỉ IP/tên miền nội bộ

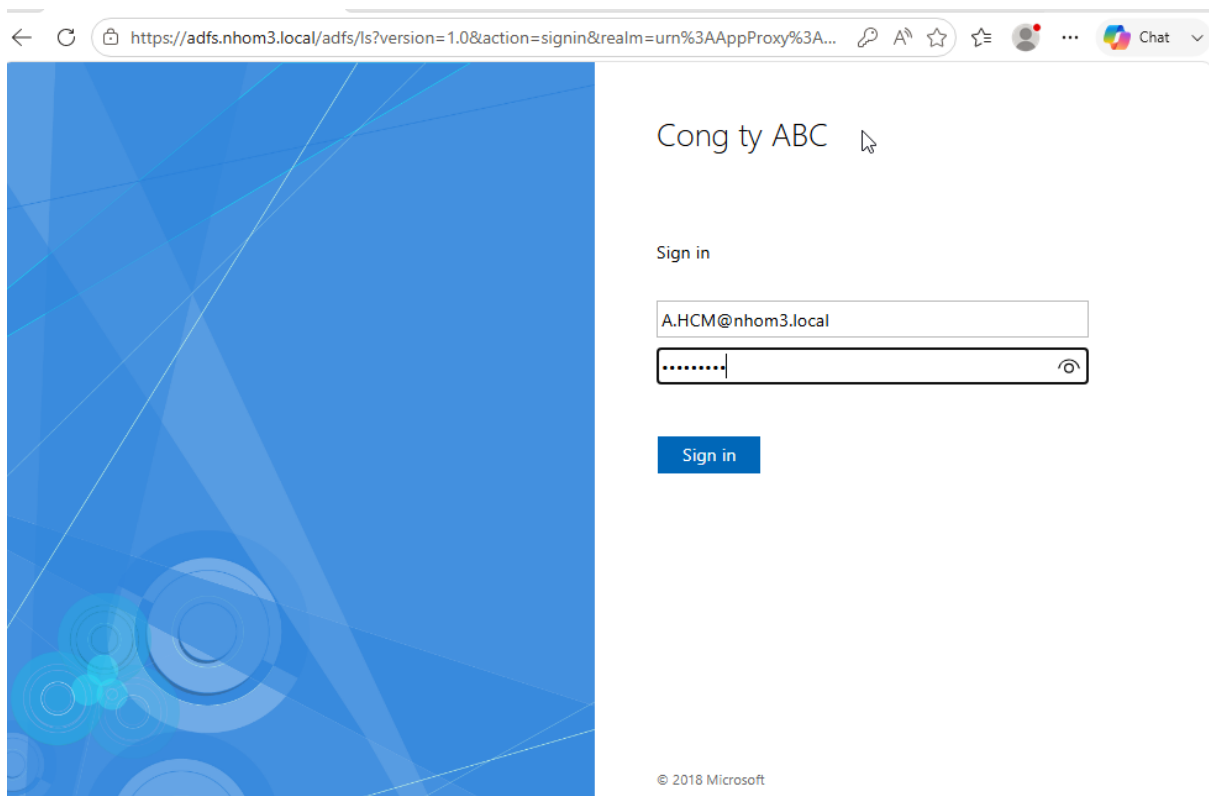
Khi client truy cập vào Web Server lúc website chưa được cấu hình chứng chỉ SSL/TLS, kết nối chỉ ở dạng HTTP thuần túy, trình duyệt sẽ cảnh báo đây là kết nối “Không an toàn/Not Secure” (hình 2.12) vì dữ liệu trao đổi giữa client và server không được mã hóa, tiềm ẩn nguy cơ bị nghe lén (sniffing) hoặc chỉnh sửa dữ liệu trên đường truyền (Man-in-the-Middle). Để khắc phục, quản trị viên tiến hành tạo và cài đặt chứng chỉ số (Certificate) cho website, sau đó ràng buộc (binding) chứng chỉ này với cổng HTTPS (443) trên Web Server.



Hình 2.13: Tạo và cài đặt chứng chỉ số (Certificate) cho Web Server

Giải pháp Web Server được triển khai kết hợp với chứng chỉ số (SSL Certificate) nhằm tăng cường tính bảo mật cho các dịch vụ web. Chứng chỉ được cấp bởi Certificate Authority (CA) nội bộ và cài đặt trực tiếp trên máy chủ, giúp xác thực danh tính của Web Server và thiết lập kết nối an toàn giữa máy chủ với các máy khách.

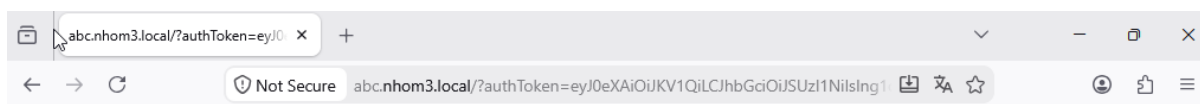
Việc sử dụng SSL Certificate giúp mã hóa dữ liệu trong quá trình truyền tải, hạn chế nguy cơ nghe lén, giả mạo hoặc thay đổi dữ liệu khi truy cập dịch vụ web. Đồng thời, chứng chỉ số còn giúp nâng cao mức độ tin cậy của hệ thống, đảm bảo người dùng kết nối đúng đến máy chủ hợp lệ và góp phần tăng cường bảo mật cho các dịch vụ được triển khai trên Web Server.



Hình 2.14. Ràng buộc (binding) chứng chỉ SSL với cổng HTTPS (443) trên Web Server

Sau khi cài đặt chứng chỉ số, hệ thống thực hiện ràng buộc (Binding) SSL Certificate với cổng HTTPS (443) trên Web Server để kích hoạt giao thức truyền tải an toàn. Khi người dùng truy cập dịch vụ web, kết nối sẽ được thiết lập thông qua giao thức HTTPS, giúp mã hóa dữ liệu trao đổi giữa máy khách và máy chủ, đồng thời xác thực danh tính của máy chủ thông qua chứng chỉ số đã được cấp.

Việc triển khai HTTPS giúp tăng cường bảo mật cho quá trình xác thực người dùng và truy cập các dịch vụ web, hạn chế các nguy cơ nghe lén, giả mạo máy chủ và thay đổi dữ liệu trong quá trình truyền tải. Đồng thời, giải pháp này cũng nâng cao độ tin cậy của hệ thống và đáp ứng yêu cầu bảo mật đối với các dịch vụ Web Server trong môi trường Domain.



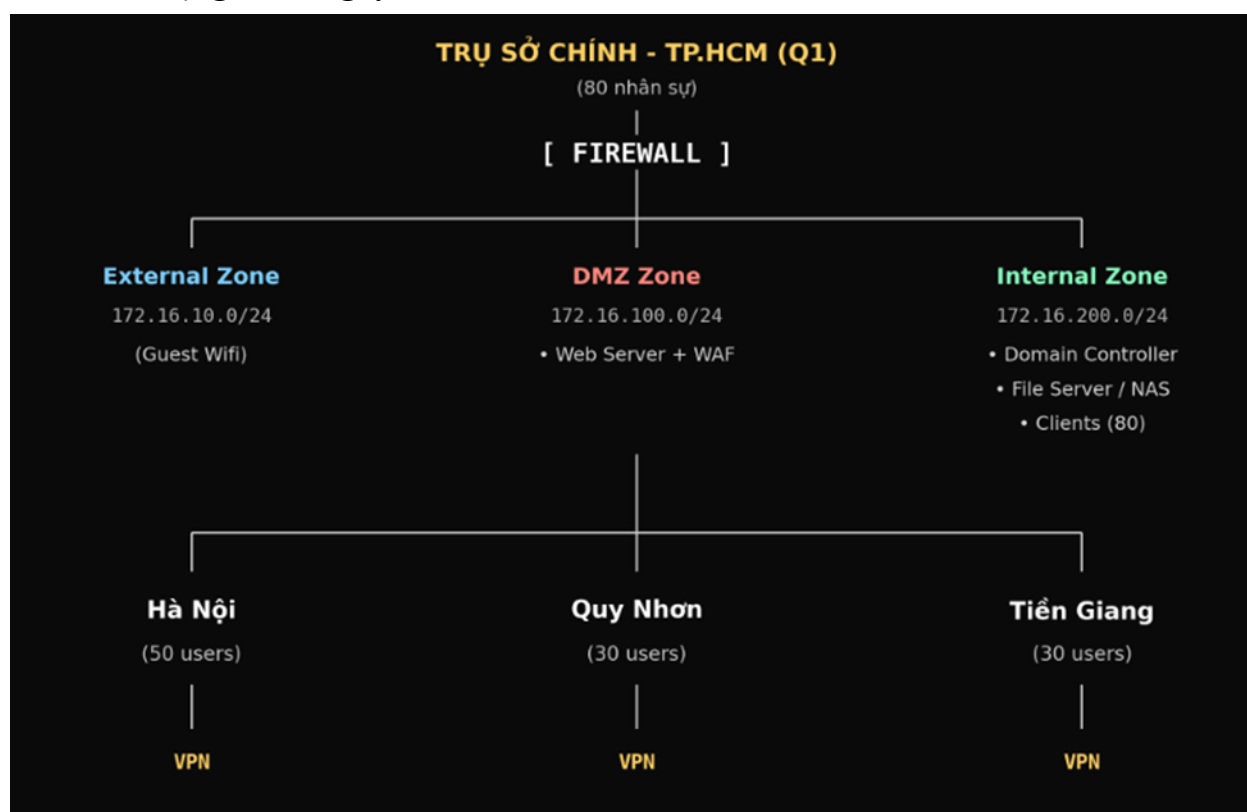
chao mung den voi cong ty ABC

Hình 2.15. Kết quả truy cập Web Server qua HTTPS sau khi cấu hình chứng chỉ thành công

Sau khi chứng chỉ SSL/TLS được cài đặt và ràng buộc thành công, trình duyệt của client hiển thị biểu tượng ổ khóa bảo mật khi truy cập website, xác nhận kết nối đã được mã hóa qua HTTPS. Toàn bộ dữ liệu trao đổi giữa client và Web Server (bao gồm thông tin đăng nhập, dữ liệu biểu mẫu) từ đó được bảo vệ khỏi nguy cơ nghe lén hoặc giả mạo trên đường truyền, đồng thời củng cố uy tín và độ tin cậy của dịch vụ web đối với người dùng.

Cung cấp dịch vụ web ra bên ngoài trong khi được cô lập khỏi mạng nội bộ (Internal Zone) thông qua vùng DMZ và cơ chế NAT Port Forwarding. Hạn chế khả năng kẻ tấn công chiếm được Web Server rồi tiến sâu vào mạng nội bộ (Domain Controller, File Server); nếu dịch vụ web bị khai thác thì thiệt hại cũng chỉ khoanh vùng trong DMZ, không lan sang các hệ thống lõi.

2.5. Sơ đồ mạng của công ty



Hình 2.16: Sơ đồ tổng thể hệ thống mạng của công ty (External Zone, DMZ Zone, Internal Zone)

Nhìn chung, việc phân vùng mạng thành External Zone, DMZ Zone và Internal Zone kết hợp với các giải pháp trên giúp công ty hạn chế được cả tác nhân bên ngoài (hacker, bot rà quét, tấn công giả mạo địa chỉ, dò mật khẩu) lẫn rủi ro phát sinh từ bên trong (người dùng thao tác sai, lạm quyền, thiết bị thất lạc), qua đó đảm bảo đồng thời ba yếu tố cốt lõi của an toàn thông tin: tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) và tính sẵn sàng (Availability) của hệ thống.

Chương 3. Kết luận, hạn chế và hướng phát triển

3.1. kết luận

Đề tài đã nghiên cứu và triển khai các giải pháp bảo mật trong môi trường mạng doanh nghiệp dựa trên nền tảng Windows Server và Active Directory. Thông qua việc xây dựng mô hình thực nghiệm, hệ thống đã đáp ứng các yêu cầu về quản lý tập trung người dùng, kiểm soát quyền truy cập, bảo vệ dữ liệu và tăng cường an toàn cho hạ tầng mạng. Quá trình triển khai cũng góp phần làm rõ vai trò của từng thành phần trong việc xây dựng một hệ thống có khả năng quản trị thống nhất và đảm bảo các yêu cầu về bảo mật.

Bên cạnh đó, việc kết hợp các giải pháp bảo mật ở nhiều lớp khác nhau đã nâng cao khả năng phòng vệ của hệ thống trước các nguy cơ truy cập trái phép, rò rỉ dữ liệu và thay đổi cấu hình ngoài ý muốn. Các cơ chế phân quyền, quản lý chính sách, mã hóa dữ liệu và kiểm soát truy cập được triển khai đồng bộ, góp phần đảm bảo tính bảo mật, tính toàn vẹn và tính sẵn sàng của thông tin trong quá trình vận hành.

Mặc dù mô hình được triển khai trong môi trường mô phỏng, kết quả đạt được cho thấy các giải pháp có tính khả thi và phù hợp với nhu cầu quản trị của các doanh nghiệp vừa và nhỏ. Trong tương lai, hệ thống có thể được mở rộng bằng việc tích hợp các giải pháp bảo mật nâng cao như xác thực đa yếu tố (MFA), hệ thống giám sát và phân tích nhật ký tập trung (SIEM), hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS), cũng như các giải pháp sao lưu và khôi phục dữ liệu nhằm nâng cao hơn nữa khả năng bảo vệ hệ thống trước các mối đe dọa an ninh mạng.

3.2. Hạn chế

Bên cạnh những kết quả đạt được, mô hình vẫn còn một số hạn chế nhất định. Trước hết, toàn bộ hệ thống mới chỉ được xây dựng và kiểm thử trên môi trường ảo hóa (VMWare/VirtualBox) với quy mô thu nhỏ, chưa được triển khai và đánh giá trên hạ tầng vật lý thực tế cũng như dưới tải truy cập đồng thời của toàn bộ 190 nhân sự tại bốn địa điểm.

Thứ hai, các thành phần trọng yếu như Domain Controller, File Server và Web Server hiện chỉ được triển khai đơn lẻ (single point), chưa có cơ chế dự phòng hay cân bằng tải (High Availability), nên nếu máy chủ gặp sự cố thì toàn bộ hoạt động liên quan sẽ bị gián đoạn.

Thứ ba, hệ thống chưa tích hợp các giải pháp giám sát và phát hiện xâm nhập chuyên sâu như IDS/IPS hay SIEM, việc phát hiện tấn công hiện chủ yếu dựa vào nhật ký (log) của Firewall nên khó phát hiện sớm các cuộc tấn công tinh vi, đa bước. Cơ chế xác thực cũng mới dừng ở mật khẩu và chính sách khóa tài khoản qua GPO, chưa áp dụng xác thực đa yếu tố (MFA) cho các tài khoản quản trị.

Cuối cùng, đề tài chưa xây dựng quy trình sao lưu, khôi phục dữ liệu (Backup & Disaster Recovery) và kịch bản ứng phó sự cố (Incident Response) một cách bài bản, đồng thời chưa thực hiện kiểm thử xâm nhập (Penetration Testing) toàn diện để đánh giá khả năng chống chịu thực tế của hệ thống trước các hình thức tấn công đa dạng.

3.3. Hướng phát triển

Trên cơ sở những hạn chế đã nêu, đề tài đề xuất một số hướng phát triển nhằm hoàn thiện hơn hệ thống trong tương lai. Về xác thực và giám sát, cần bổ sung xác thực đa yếu tố (Multi-Factor Authentication - MFA) cho các tài khoản quản trị và truy cập từ xa qua VPN, đồng thời triển khai hệ thống thu thập, phân tích nhật ký tập trung (SIEM) kết hợp với giải pháp phát hiện và ngăn chặn xâm nhập (IDS/IPS) để nâng cao khả năng phát hiện sớm các cuộc tấn công nhiều bước.

Về tính sẵn sàng của hệ thống, cần xây dựng cơ chế dự phòng và cân bằng tải (High Availability) cho Domain Controller, File Server và Web Server, đồng thời thiết lập quy trình sao lưu, khôi phục dữ liệu (Backup & Disaster Recovery) định kỳ cùng kịch bản ứng phó sự cố (Incident Response Plan) rõ ràng cho từng loại tình huống.

Về quy mô triển khai, hệ thống nên được thử nghiệm trên hạ tầng vật lý thực tế với số lượng người dùng gần với con số 190 nhân sự thực tế, đồng thời thực hiện kiểm thử xâm nhập (Penetration Testing) định kỳ để đánh giá khách quan khả năng chống chịu trước các hình thức tấn công đa dạng.

Cuối cùng, bên cạnh các giải pháp kỹ thuật, doanh nghiệp cần xây dựng chương trình đào tạo nhận thức an toàn thông tin (Security Awareness Training) định kỳ cho nhân viên và ban hành bộ chính sách an toàn thông tin (ISMS) theo các tiêu chuẩn như ISO/IEC 27001, nhằm đảm bảo yếu tố con người và quy trình quản trị đồng bộ với các giải pháp kỹ thuật đã triển khai.

TÀI LIỆU THAM KHẢO

1) Microsoft Corporation. (2024). Active Directory Domain Services Overview.

<https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>

2) Microsoft Corporation. (2024). Group Policy Overview.

<https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/group-policy/group-policy-overview>

3) Microsoft Corporation. (2024). BitLocker Drive Encryption Overview.

<https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/>

4) Microsoft Corporation. (2024). Internet Information Services (IIS) Documentation.

<https://learn.microsoft.com/en-us/iis/>

5) Netgate. (2024). pfSense® Software Documentation.

<https://docs.netgate.com/pfsense/en/latest/>

6) OpenVPN Inc. (2024). OpenVPN Access Server Documentation.

<https://openvpn.net/access-server-manual/>

7) Web Server. (2025). Pixel Academy VN

<https://www.youtube.com/watch?v=7W8NkhzN40g&t=1429s>